AUTONOSERVICE · INFORME ÚNICO DE AUDITORÍA PARA CODEX

Documento único y accesible en GitHub. Fecha de corte de la auditoría: 30/10/2026. El código de la aplicación ha seguido avanzando después de ese corte, incluido el PR #19 para el icono de iPhone. Revisar siempre el estado actual de `main` antes de aplicar correcciones.

Contenido

1. Auditoría integral técnica y funcional: comprobaciones ejecutadas, resultados y fallos.
2. Plan exhaustivo de **158 casos de aceptación**, principalmente pendientes de ejecutar.
3. Instrucciones concretas para Codex, prioridades, criterios de entrega y límites de seguridad.

> **Nota de alcance:** las 382 comprobaciones del smoke público no equivalen a 382 pruebas de flujos autenticados; la suite Playwright local histórica registró 11 aciertos y 16 fallos. No afirmar cobertura total. No ejecutar acciones destructivas sobre los datos existentes.

Auditoría integral

AUTONOSERVICE — AUDITORÍA INTEGRAL DE PRODUCTO, CÓDIGO, BASE DE DATOS Y WEB

Fecha: 30 de octubre de 2026
Preparado para: siguiente sesión de desarrollo con Codex
Repositorio: https://github.com/quimfuentes28code/EZ-SHOP
Aplicación: https://autonoservice.quim-fuentes28.workers.dev/
Última versión de `main` analizada: `773c6d7c653c98ae548e4e4087c3bf29d492d5db` (PR #16)
Principio: una misma identidad permite activar Empresa y Cliente; los negocios, sus sedes y los datos de sus clientes se mantienen separados según su dominio y permisos.

> **Límite imprescindible:** Esta auditoría combina evidencias reales con comprobaciones estáticas. Las rutas públicas se han probado mediante navegadores reales automatizados, los permisos de Supabase se han inspeccionado y se han hecho pruebas SQL reversibles, y el código se ha revisado. **No se dispone de dos sesiones de navegador de prueba confirmadas**, por lo que no puede afirmarse

> que todos los flujos autenticados funcionen de extremo a extremo. El documento distingue con precisión lo verificado, lo implementado sin prueba E2E y lo pendiente. Una prueba que busca una cadena en el código no equivale a pulsar el botón con una sesión real.

Actualización: segunda ronda de prueba → error → corrección (30/10/2026)

Esta actualización se ha completado **en la sesión actual**, no mediante un agente trabajando seis horas en segundo plano. Los resultados siguientes están fundamentados en ejecuciones reales de CI de GitHub. No afectan a empresas ni datos de producción.

Contexto empresarial A/B — PR #18 (propuesta de corrección todavía SIN fusionar): https://github.com/quimfuentes28code/EZ-SHOP/pull/18

- **Defecto identificado por inspección:** `BusinessTools` conservaba `enabled` y `saved` al cambiar de organización, y no los limpiaba si la siguiente empresa carecía de preferencias de módulos. Las consultas asíncronas previas podían terminar después del cambio. `RealExperience` tampoco vaciaba servicios y contactos de la empresa anterior en el mismo evento de cambio.
- **Primera corrección:** se añadió reinicio de preferencias, cancelación lógica de respuestas tardías, nueva identidad React `key={selectedOrg}` para `BusinessTools` y una función común de cambio de empresa para selector lateral, selector de gestión y selector móvil.
- **Prueba fallida detectada al iterar:** la ejecución https://github.com/quimfuentes28code/EZ-SHOP/actions/runs/40984514001 falló en una comprobación estática antigua, que buscaba directamente `setSelectedOrg(e.target.value)`. No se ignoró el resultado ni se atribuyó a Supabase.
- **Segunda corrección:** el test existente se adaptó al nuevo contrato `changeActiveOrganization(...)`. La ejecución completa de TypeScript, tests unitarios y build resultó correcta: https://github.com/quimfuentes28code/EZ-SHOP/actions/runs/40984591264 (commit `9d0938d29431ded14b1df5728d332563c632643a`).
- **Límite vigente:** pasar la compilación **no demuestra** el cambio A/B real en móvil con sesión autenticada; queda pendiente probarlo en staging con dos empresas y red lenta. **No dar por aplicado el fix en Cloudflare** mientras el PR #18 siga abierto.

Matriz adicional: `AUTONOSERVICE_PLAN_PRUEBAS_EXHAUSTIVO_2026-10-30.md` contiene **158 casos de aceptación**, clasificados en 79 P0, 77 P1 y 2 P2. Son **casos que Codex deberá ejecutar** con cuentas de QA, no resultados positivos ya observados. Incluye testigos negativos de permisos, funcionamiento cruzado Empresa/Cliente y compatibilidad móvil.

Estado final de evidencia combinada: smoke público **382/382**; E2E histórico **11/27**; CI del fix de organización **verde tras una iteración fallida**; sesiones autenticadas integrales **sin ejecutar**. La recomendación de lanzamiento no cambia: **no apto para apertura general**.

1. Resumen ejecutivo

Conclusión: AutonoService tiene ya una base técnica y visual funcional, conectada a Supabase, pero **no está listo para una apertura comercial general**. El transporte de las páginas públicas es estable; los riesgos centrales ya no son tanto errores de compilación como cobertura insuficiente de flujos con identidad real, consistencia del cambio entre empresas, separación entre demostraciones y producto, comportamiento de mensajes, controles de privacidad y lanzamiento/observabilidad.

Evidencia objetiva de esta revisión

- Auditoría de la web publicada: **382 comprobaciones registradas, 0 fallos** entre Chromium escritorio, Chromium de 360 px, Chromium tablet, Firefox escritorio y WebKit con emulación de iPhone 13. Incluye respuestas HTTP, carga no vacía, excepciones JavaScript, desbordamiento horizontal, guardas de sesión y formulario de acceso. **No son 382 funcionalidades distintas.**
- Ejecución y capturas: https://github.com/quimfuentes28code/EZ-SHOP/actions/runs/40982101322 . La evidencia JSON/capturas está en el artefacto `deep-live-audit-20261030` de ese run.
- Suite E2E local completa, ejecutada **adicionalmente** en un workflow de auditoría: **27 casos, 11 superados y 16 fallidos**. La mayoría de fallos esperan rutas/DOM antiguos del prototipo; no equivalen a 16 errores confirmados de producción. Evidencia: https://github.com/quimfuentes28code/EZ-SHOP/actions/runs/40982450589 .
- En la compilación de `/empresa` ya publicada aparecen `location-delete-confirmation`, `Eliminar definitivamente`, `business-live-mobile-company-switcher` y `as-company-hero`. **El despliegue contiene el código** de eliminar sedes, cambiar de empresa en móvil y rediseñar perfiles; esto **no prueba** su funcionamiento autenticado.
- GitHub `main` pasó TypeScript, pruebas unitarias y compilación para el commit anterior a la auditoría: https://github.com/quimfuentes28code/EZ-SHOP/actions/runs/40979936103 .
- Supabase: **14/14 tablas de negocio con RLS activado**; 17 migraciones registradas, incluida `allow_owned_location_deletion`.
- Borrado de sedes: se insertó una **sede sintética en una transacción que terminó con `ROLLBACK`**. El propietario pudo borrarla, otra identidad no pudo borrar una sede sintética ajena y al finalizar no quedó ningún registro de prueba. Es verificación de SQL/RLS, **no** de la interfaz móvil.
- Asesor de seguridad: sigue apareciendo **`auth_leaked_password_protection` desactivado**; https://supabase.com/docs/guides/auth/password-security#password-strength-and-leaked-password-protection .
- Asesor de rendimiento: 7 índices nuevos sin utilización observada, aviso informativo razonable con tráfico escaso; no eliminarlos por ese aviso sin medir consultas.

Fotografía de datos reales observada

Dato	Observación al auditar	Interpretación
Empresas	2	RedMoonCorp y RedMoonStudios
Empresas publicadas	2	Visibles para consultas autenticadas autorizadas
RedMoonCorp	Portada y logo guardados	Ya figura publicada al hacer esta auditoría
RedMoonStudios	Sin portada ni logo guardados	No hereda la imagen de RedMoonCorp: los perfiles son distintos
Sedes	2	Una por cada empresa
Sedes publicadas	0	El mapa real no tiene ubicaciones públicas que mostrar
Sedes públicas con coordenadas	0	No inventar pines; publicar voluntariamente una sede y su punto
Servicios	1	No demuestra los flujos CRUD completos

Dato	Observación al auditar	Interpretación
Publicaciones	1	No demuestra todos los estados de publicación
Conversaciones / mensajes	2 / 5	Hay datos persistidos; falta E2E de envío/lectura con dos cuentas
Solicitudes de servicio	0	No hay evidencia de un flujo de contratación real completado
Registros de proyectos/trabajos	0	Herramientas creadas en código, persistencia no validada E2E
Preferencias de módulos	0	No consta todavía un guardado real verificable

No se han modificado empresas, publicaciones, contactos ni mensajes existentes. El reporte no contiene direcciones de correo, tokens, contraseñas ni datos privados de terceros.

2. Escala de evidencias

- **V-BROWSER:** validado en el navegador de la web publicada sin sesión.
- **V-SQL:** confirmado en Supabase mediante consultas o transacciones revertidas.
- **V-CI:** comprobado por TypeScript, unitarias o build. No implica un usuario real.
- **INSPECCIÓN:** el código realiza aparentemente la función, pero falta una prueba de extremo a extremo.
- **REPORTADO:** comportamiento informado por el propietario, no reproducido por el auditor.
- **PENDIENTE:** no implementado o no verificado.

No usar el término «funciona» indiscriminadamente: el objetivo de Codex es transformar cada fila **INSPECCIÓN/PENDIENTE** en un caso de prueba verificable, y resolver los defectos confirmados.

3. Auditoría funcional por áreas

Funcionalidad	Estado	Evidencia o límite	Siguiente prueba de aceptación
Inicio y elección Empresa/ Cliente	V-BROWSER	Carga y enlaces presentes	Verificar navegación de ambos botones en móvil físico
Registro Cliente y Empresa: interfaz	V-BROWSER	Entradas y alternancia crear/acceder	Verificaciones de email y errores reales de Auth
Inicio de sesión real y persistencia	INSPECCIÓN	Se usa Supabase Auth; no hay sesión de QA confirmada	Login, refresh, cerrar sesión, token caducado
Activar Empresa y Cliente en un correo	INSPECCIÓN	`account_types`; diseño unificado	Identidad con ambos roles; cambio sin perder contexto
Cambiar entre RedMoonCorp y RedMoonStudios en escritorio	INSPECCIÓN	Selector lateral en código	Cambiar desde cada pestaña y verificar datos

Funcionalidad	Estado	Evidencia o límite	Siguiente prueba de aceptación
Cambiar empresa en móvil	V-CI + BUNDLE	Selector móvil en compilación; el usuario lo había reportado como ausente	iPhone real, select nativo, cada sección actualizada
Crear una empresa	INSPECCIÓN	Inserción con propietario y trigger de una empresa nueva por cuenta	Nuevo usuario de prueba; límite y creación de sede principal
Crear más de una empresa nueva	LIMITADO POR DISEÑO	Trigger impide una segunda empresa por propietario nuevo; las dos existentes se conservaron	Definir claramente empresa versus sucursal
Publicar/ocultar empresa	V-SQL de estado, INSPECCIÓN UI	Ambas empresas publicadas; editor y panel tienen controles	Publicar, ocultar y comprobar otro Cliente
Nombre, categoría, ciudad y descripción	INSPECCIÓN	Formulario UPDATE implementado	Editar, recargar, cambiar empresa, volver
Subir portada/logo	V-SQL + REPORTADO	RedMoonCorp tiene URLs y el propietario confirma verla desde Cliente	JPG/PNG/WebP, límite, fallo red, reload, móvil
Apariencia del perfil Cliente	V-CI + BUNDLE	Hero, logo y secciones implementadas, CSS responsive	Revisión visual autenticada real en varios tamaños
Perfil público para compartir sin cuenta	PENDIENTE	Enlace `/cliente?negocio=UUID` requiere contexto Cliente registrado	URL pública propia, RLS y vista SEO/anon
Crear servicios y precios	INSPECCIÓN	`organization_services` conectado	Crear, listar, actualizar, desactivar y borrar (faltan controles completos)
Solicitar servicio	INSPECCIÓN	`service_requests.insert` implementado	Solicitud de Cliente A y recepción Empresa B
Cambiar estado de solicitudes	INSPECCIÓN	UPDATE del propietario	Aceptar/rechazar/completar; reflejo en Cliente
CRM de clientes por empresa	INSPECCIÓN	Tabla de relación y consultas	Ver solo contactos autorizados; evitar datos cruzados
Tiendas y sedes: crear/editar	INSPECCIÓN	CRUD y selección de ubicación en código	Comprobar guardado y horarios, coordenadas y visibilidad
Tiendas y sedes: eliminar	V-SQL + V-CI + BUNDLE	Regla de propietario probada; botón en código publicado	Pulsar, confirmar nombre, borrar, recargar, confirmar aislamiento
Sede principal al eliminarse	LIMITACIÓN DE DISEÑO	Se avisa, pero no se asigna nueva principal	Diseñar selección/transferencia o impedir borrar la última

Funcionalidad	Estado	Evidencia o límite	Siguiente prueba de aceptación
Mapa de negocios reales	INSPECCIÓN + DATOS VACÍOS	Leaflet, coordenadas voluntarias; **0 ubicaciones publicadas**	Publicar una sede de prueba y confirmar pin desde Cliente
Filtros de Explorar: texto/ ciudad/categoría	INSPECCIÓN	Filtrado cliente sobre negocios reales	Pruebas autenticadas, acentos, vacíos, decenas de registros
Seguir/guardar favorito	INSPECCIÓN	`customer_favorites` RLS; 1 fila actual	Dos cuentas, añadir/quitar, persistencia y feed
Publicaciones de empresa	INSPECCIÓN	Texto/imagen/vídeo, publicación/borrador	Subir, ocultar, borrar y comprobar Cliente
Novedades de negocios seguidos	INSPECCIÓN	Usa posts reales asociados a favoritos	Feed desde Cliente con dos empresas seguidas
Chat Cliente/Empresa texto	INSPECCIÓN + DATOS	2 hilos y 5 mensajes existentes; polling	Chat bidireccional 2 cuentas, mensajes aislados
Chat con PDF/TXT/imágenes privadas	INSPECCIÓN	Bucket privado, URL firmada temporal	Subir, descargar como miembro y denegar a tercero
Notificaciones de no leídos	INSPECCIÓN	`conversation_read_states` y polling 6 s	Dos usuarios, leer/no leer y roles diferenciados
Realtime/Push	PENDIENTE	No hay WebSocket/Push real; refresco cada 6 s	No anunciar tiempo real instantáneo
Proyectos, agenda y trabajo interno	INSPECCIÓN	Registros `business_work_items` y estados	Crear y reabrir por empresa, persistir en otro dispositivo
Presupuestos	PARCIAL	Solo borradores de importe; no emisión de PDF ni envío	Delimitar alcance y no llamar facturación
Módulos destacados por empresa	INSPECCIÓN	`organization_module_settings`	Guardar en A, cambiar a B y verificar que no arrastra estado
Demostraciones `/demo/*`	V-BROWSER + UNITARIAS	Contenido ficticio y almacenamiento local	Mantener señalización visible de demo
Modo claro/oscuro	INSPECCIÓN	`ThemeToggle` presente	Persistencia y contrastes en móvil físico
Pagos, licencias, facturación, reservas de capacidad	PENDIENTE	No hay backend comercial de estas capacidades	No mostrar como servicios operativos

4. Incidencias y riesgos priorizados para Codex

P0 — Bloqueos de lanzamiento abierto

P0-01: No hay evidencia E2E autenticada integral; además, la suite E2E local completa falla (16/27 casos). Las pruebas automáticas existentes de Playwright se centran mayoritariamente en el prototipo local y las demostraciones; los tests recientes del selector, perfiles y borrado son comprobaciones del código fuente mediante expresiones regulares. Consecuencia: un fallo de Auth, RLS, navegador, carga, permisos o estado del componente puede llegar a producción sin que el CI lo detecte. **Acción:** construir un entorno QA con dos cuentas confirmadas y datos sintéticos, credenciales en secretos, pruebas reproducibles de Empresa → Cliente y eliminación/limpieza segura. No confundir pruebas de SQL con pruebas de navegador.

P0-02: protección de contraseñas filtradas desactivada antes de abrir el registro al público. Verificado por Supabase Security Advisor. Activarla y documentar ajustes de Auth y recuperación de contraseña. No bloquear el entorno de desarrollo por declarar que todo es producción si aún está en piloto; sí bloquear el lanzamiento masivo.

P0-03: pruebas de aislamiento de datos obligatorias antes de usar datos reales de clientes. A pesar de que las tablas tienen RLS y se han verificado permisos concretos, faltan pruebas automatizadas negativas cruzadas de perfil, CRM, mensajes, archivos y solicitudes para propietario A, propietario B, Cliente A, Cliente B, invitado. La posibilidad de activar ambos roles hace especialmente importante el contexto activo y evitar respuestas mezcladas.

P1 — Problemas concretos de producto y de implementación

P1-01: “Eliminar tienda” existe en código publicado, pero su ubicación no coincide necesariamente con lo que busca el usuario. Se encuentra en **Empresa → Tiendas y sedes**, en cada tarjeta de sede. No es «Eliminar empresa» en el selector de negocios ni en Perfil público. El propietario reporta que no lo encuentra. Añadir navegación clara, un bloque «Gestión de sedes» visible en móvil y prueba con sesión real. Si se pretende borrar RedMoonCorp/RedMoonStudios como **empresas**, diseñar flujo separado con auditoría, exportación/retención, seguridad de datos y confirmación; **no implementar directamente** `DELETE FROM organizations`, pues las claves externas están configuradas con cascada sobre servicios, chats, solicitudes y otras tablas.

P1-02: el cambio de empresa puede arrastrar visualmente preferencias de herramientas. En `src/components/business-home.tsx`, `BusinessTools` conserva `enabled` y `saved` entre cambios de `organizationId`; en el `useEffect`, cuando la nueva empresa no tiene fila en `organization_module_settings`, no se limpia el estado previo (`else if(data)`). También puede finalizar tarde la consulta a la empresa anterior. **Reproducción:** configurar módulos de empresa A; cambiar a empresa B sin fila de configuración; observar los módulos mostrados y el estado de “Guardado”. **Arreglo:** `key={selectedOrg}`, reiniciar `enabled` y `saved`, protección contra respuestas obsoletas, test de regresión de dos organizaciones.

P1-03: contenido transitorio de otra empresa al cambiar la seleccionada. En `src/components/real-experience.tsx` el efecto que carga servicios y contactos al cambiar `selectedOrg` no limpia de forma inmediata los datos anteriores; durante el fetch pueden verse servicios/CRM de la empresa previa. Aunque el propietario sea el mismo, la interfaz podría inducir a editar datos equivocados. **Arreglo:** resetear arrays al cambiar `selectedOrg`, estado de carga e invalidar respuestas tardías; tests cambiando A/B repetidamente con red lenta.

P1-04: rutas anunciadas como “perfil público” siguen dentro de `/cliente` autenticado. Enlace `/cliente?negocio=<uuid>` no es un perfil accesible sin cuenta ni ruta SEO independiente. **Arreglo:** URL pública estable por slug/ID, RLS para anónimos, diseño de cabeceras SEO, 404 privado/no publicado y botón de entrar a Cliente para enviar mensajes. Mantener separados perfiles comerciales y privados.

P1-05: consulta anónima a negocios publicados falla por permisos asociados a RLS. Reproducción SQL sin token de usuario, `BEGIN; SET LOCAL ROLE anon; SELECT count(*) FROM public.organizations; ROLLBACK;`, devuelve **`42501 permission denied for table account_types`**. Ocurre también al consultar `business_posts`, `organization_locations` y `organization_services`. El SELECT público de estas tablas usa expresiones RLS que dependen de `account_types`, cuya lectura no está concedida al rol anónimo. Esto no invalida necesariamente el directorio autenticado actual, pero bloquea el futuro perfil público anónimo. **Arreglo:** ajustar permisos y arquitectura de RLS de manera mínima y comprobada (sin publicar membresías ni datos internos); verificar con cliente Supabase `anon`, rol `authenticated` y usuario propietario, incluyendo casos negativos. No resolver desactivando RLS ni exponiendo cuentas completas.

P1-06: desajuste de historial del navegador en Cliente. `src/components/customer-social.tsx`: `selectTab()` llama a `closeBusinessProfile()` aun cuando no existe perfil abierto; esta función siempre ejecuta `history.pushState`. Cerrar un perfil también agrega una entrada nueva, de modo que el botón Atrás puede reabrir la ficha recién cerrada o pasar por entradas equivalentes. **Arreglo:** no modificar URL sin cambio real; decidir `back`/`replaceState` según cómo se entró; pruebas Playwright de abrir perfil, volver, pestañas y retroceso/avance, tanto directo como desde Explorar.

P1-07: carga de ficheros potencialmente huérfanos. `BusinessSocialEditor.upload()` sube primero a Storage y luego hace UPDATE/INSERT en Postgres. Si esta segunda operación falla, el archivo puede quedar en el bucket sin referencia. En los reemplazos de portada/logo los archivos antiguos tampoco se eliminan sistemáticamente. **Arreglo:** limpieza compensatoria segura tras fallo, historial de archivos o flujo server-side con control de propiedad, tests de fallo simulado, evitar borrado de medios compartidos o todavía referenciados.

P1-08: publicación de imágenes en bucket público incluso para negocios privados. La visibilidad del negocio se comprueba en las tablas, pero el bucket `autonoservice-public-media` es público por diseño: quien conozca una URL puede abrir el archivo aunque la empresa esté oculta. La UI avisa de que los medios públicos son públicos, pero **privado no debe inducir a creer que la URL de archivo es secreta**. Definir contrato claro, revocación de medios cuando proceda y separación explícita de adjuntos privados.

P1-09: los servicios reales solo admiten crear y listar de forma sencilla en el panel. Falta una gestión completa para editar, archivar, desactivar, reordenar, eliminar (considerando solicitudes existentes), imágenes, disponibilidad y distinción servicio/producto según sector. No presentar como un catálogo comercial completo.

P1-10: no hay sedes publicadas; mapa “vacío” aunque exista código funcional. Las 2 sedes están privadas y 0 disponen de coordenadas públicas. Añadir un recorrido de configuración «Publicar sede en el mapa» con consentimiento explícito, geocodificación opcional y vista previa, sin forzar compartir dirección residencial.

P1-11: ciclo de solicitudes limitado. Se soporta insertar y cambiar `new/accepted/rejected/completed` en código, pero no un motor real de disponibilidad, conflictos, cancelaciones, políticas de modificación, recordatorios o confirmación de reserva. Probar status, comentarios y permisos sin inventar horarios reservables.

P2 — Calidad técnica, escala, rendimiento y UX

P2-01: polling de chats a intervalos fijos de 6 s. `src/components/social-inbox.tsx` consulta hilos, mensajes y no leídos continuamente. Además hace `upsert` de `read_at` tras cargar mensajes cada ciclo. A escala produce peticiones/escrituras evitables, tráfico en pestañas en segundo plano y posible refresco visual. Solo mostrar “se actualizan aproximadamente cada seis segundos”; valorar Supabase Realtime, visibilidad de pestaña, backoff y confirmación de lectura por evento de apertura, no por cada refetch.

P2-02: consultas sin paginación real. Cliente carga todas las empresas publicadas, servicios y sedes; posts limitados globalmente a 120, mensajes a 200 y contador de no leídos a 2.000. Escalar con paginación/cursores, índices observados, límites, búsqueda en servidor y pruebas de múltiples miles de filas.

P2-03: fiabilidad de imágenes y portadas. Verificar `onError`, caché de CDN, subida cancelada, red 3G, orientación/relación de aspecto, archivo corrupto, archivo demasiado pesado, WebP/iOS, avatar/logo y visibilidad entre dos navegadores. Añadir UI que identifique empresa activa y la imagen realmente persistida.

P2-04: dependencia externa de mapas. Leaflet se carga desde unpkg y las teselas de OpenStreetMap desde un proveedor público. Riesgo de CDN indisponible/cuotas/condiciones de uso; introducir proveedor configurable, manejo de errores, accesibilidad del mapa y estrategia de costes y uso comercial.

P2-05: navegación móvil y accesibilidad. Probar tamaños 320, 360, 375, 390, 430, 768, 1024 y 1440 px; teclado y VoiceOver/TalkBack; focus visible, elementos de al menos 44 × 44 px cuando corresponda, `aria-label` significativo, contraste y movimiento reducido. La confirmación destructiva actual no implementa un diálogo modal con gestión de foco; su diseño debe revisarse.

P2-06: datos comerciales y feeds como producto social. La página de empresa ya presenta una cabecera más rica, pero aún faltan galerías organizadas, vídeos destacados, publicaciones fijadas, categorías, enlaces de marca, horarios consistentes, contacto más completo y personalización modular. No es prioridad sobre seguridad y E2E.

P2-07: documentación desfasada. README y ROADMAP todavía dicen que Hito 1 no ha empezado, que no hay mapa real/RLS o que `/empresa` y `/cliente` son solo demostraciones. Esto ya no coincide con las migraciones, módulos reales ni el directorio autenticado. Actualizar documentación separando `demo`, `real implementado` y `pendiente`, y el modelo una identidad/dos espacios.

P2-08: faltan controles de producto y operaciones. Política de privacidad/cookies cuando corresponda, condiciones del servicio, mecanismos RGPD (exportación/retención/eliminación), moderación de negocios y spam, bloqueo/denuncia en chat, cuentas empleadas, logs de auditoría, respaldo y restauración, control de costes, incidentes, alertas y métricas. No desplegar funcionalidades reguladas sin definición legal.

P2-09: proceso de release insuficientemente auditable. El workflow `Verify web prototype` valida TypeScript, tests y estáticos, **no despliega Cloudflare**. La auditoría comprobó por contenido de los bundles que una versión reciente está publicada, pero no hay exposición fiable de SHA de deployment, verificación automática posdespliegue o rollback documentado. Crear etiqueta/build manifest de versión y comprobaciones públicas + autenticadas en staging.

5. Seguridad y modelo de datos

Qué sí se ha verificado

- 14 tablas en esquema `public` tienen **RLS enabled**; la mayoría de políticas de lectura/escritura filtran por `auth.uid()` y pertenencia a Empresa/Cliente.
- `organization_locations`: ahora hay una política `DELETE` que exige propietario y membresía empresarial; el rol `anon` no tiene permiso DELETE. Prueba SQL reversible de propietario permitido y tercero rechazado.
- Los archivos de mensajes pertenecen al bucket privado `autonoservice-private-chat`; el cliente usa URL firmada de 60 segundos. El bucket de marketing/publicaciones es público y debe tratarse como tal.
- La visibilidad del mapa depende de `published` de sede **y** empresa, y requiere coordenadas elegidas voluntariamente.
- Las claves foráneas importantes existen; las tablas que dependen de una organización usan frecuentemente `ON DELETE CASCADE`: **no permitir borrar una empresa completa con un DELETE simple sin política de retención y exportación**.

Qué debe verificarse antes del lanzamiento

1. Cuenta Empresa A ve únicamente sus CRM, trabajos y mensajes; Empresa B no lee, modifica ni borra sus filas.
2. Cliente A puede ver solo sus solicitudes, favoritos, conversaciones y adjuntos; Cliente B no accede a ellos, ni siquiera cambiando UUID.
3. Una identidad con roles Empresa y Cliente no mezcla hilos personales y profesionales; un emisor no puede falsificar `actor_role`.
4. Invitado anónimo solo ve negocios, sedes, servicios y posts publicados, sin exponer `account_types`.
5. PDF/imagen/TXT de chat no descargable por una cuenta ajena usando ruta de Storage ni `createSignedUrl`.
6. Restricciones de MIME/tamaño validadas en cliente y servidor; pruebas de archivo malformado, subida a ruta ajena, permisos de lectura y limpieza.
7. Revocación/caducidad de sesión y token, restablecimiento de contraseña, protección de password filtrado y validación de email.
8. Borrados sin cascadas accidentales y con restauración/retención de información empresarial que deba conservarse.

Hallazgo de `anon` a reproducir por Codex

```
begin;
set local role anon;
select count(*) from public.organizations;
rollback;
```

Resultado observado: error `42501 permission denied for table account_types`. Antes de corregir, examinar `pg_policies` y privilegios de `anon`; usar una solución de mínimo privilegio, probarla en entorno no productivo y aplicar migración trazable. No desactivar RLS como atajo.

6. Calidad de pruebas y matriz exigida

Pruebas actuales

- `npm run typecheck`, `npm test`, `npm run build`: ejecutadas en CI y correctas para `main` hasta el commit auditado.
- Tests unitarios antiguos: bastante cobertura de **datos de demostración/localStorage**; útiles para prototipo, no prueban Supabase real.
- Tests unitarios recientes: varios usan `readFileSync(...)` y expresiones regulares para demostrar que existe código, clases CSS o migraciones. No ejercitan el botón ni simulan condiciones reales.
- `tests/e2e/*.spec.ts`: principalmente rutas demo locales, no llamadas autenticadas reales a Supabase. **No usar estas pruebas como garantía de CRM/mensajería real**.
- **Resultado recién obtenido:** `npm run test:e2e` en la rama de auditoría: **11 passed / 16 failed, 27 en total** (aprox. 5,3 minutos). El workflow ordinario de `main` no ejecuta esta suite. Los fallos se analizan en el apartado 6.1; los fallos de pruebas antiguas no deben etiquetarse automáticamente como defectos del producto actual.
- Nueva batería externa: 382 comprobaciones, 0 fallos, 5 combinaciones de motor/viewport. WebKit en Linux es aproximación al motor Safari, no iPhone físico.

6.1. Resultado real de las 27 pruebas Playwright locales (16 fallidas)

Ejecución: https://github.com/quimfuentes28code/EZ-SHOP/actions/runs/40982450589 (incluye capturas y trazas de los fallos). **11 correctas, 16 fallidas**. Todos los casos ejecutados contra un servidor local Next.js en GitHub Actions, no contra la web de producción.

Grupo	Casos fallidos	Causa inmediata observada	Interpretación
`hito-0.spec.ts`	10	Cuatro pasos de onboarding esperan encabezados ficticios; navegación por módulos/Cliente antiguo; tres casos de `:focus` incluyen el portal de DevTools; menú lateral antiguo con `#business-navigation` inexistente	Pruebas desactualizadas o selectores frágiles; inspeccionar los pasos que todavía deben conservarse
`master-spec.spec.ts`	3	Un test espera `/onboarding` pero el botón ya va a `/registro/empresa`; otro espera un selector de demostración en la experiencia real; otro no encuentra el cambio de tema como estaba previsto	Contratos históricos modificados; escribir contratos actuales separados para Demo y Real
`social-revision.spec.ts`	3	Editor local antiguo no existe en `/empresa`; solicitud demo no aparece en `/cliente` protegido; respuesta de mensaje local no aparece tras cambiar perspectiva	Dos pruebas diseñadas para navegación obsoleta y un caso de demo/mensajes que requiere diagnóstico real

No corregir estas pruebas cambiando la aplicación real hacia las rutas antiguas. Actualizarlas tras revisar la especificación vigente: una identidad y dos espacios, demo separada, producción real autenticada. Ejecutar los casos de demo en `/demo/empresa` y `/demo/cliente` cuando corresponda; para la experiencia real usar usuarios de prueba y contratos de datos reales. Para los tres casos de foco, apuntar a elementos relevantes en lugar de `locator(':focus')` global, que incluye DevTools en modo `next dev`.

La prueba de mensajes demo que falla al volver a la perspectiva Cliente (`tests/e2e/social-revision.spec.ts` hacia la línea 253) merece investigar si existe un bug en la persistencia local del hilo o simplemente cambio de modelo/selector. No atribuirla a `SocialInbox` real sin reproducirla allí.

Acción de CI imprescindible: añadir un workflow separado para E2E moderno que use un entorno de staging con secretos y fixtures; mantener los tests de demos en suite independiente y dejar de considerar «CI verde» como prueba completa cuando `npm run test:e2e` falla fuera del workflow principal.

Plan reproducible para la suite autenticada de QA

Entorno: Supabase staging con datos sintéticos o proyecto aislado, nunca cuentas de clientes reales. Crear dos identidades Empresariales y dos de Cliente mediante método seguro de test, además de una identidad con ambos roles. Secretos en GitHub Actions, no en repositorio ni en logs. Restablecer fixtures y limpiar al terminar. No crear clientes ficticios permanentes en producción.

ID	Recorrido	Aceptación
QA-01	Registro Empresa, verificación, login, refresh, logout	Sesión y errores válidos; no exposición de datos
QA-02	Activar Cliente sobre cuenta Empresa	Mismo correo; ambos espacios, no perfiles duplicados
QA-03	Cambiar empresa A ↔ B en móvil	Cabecera y cada módulo muestran la correcta; sin estado residual
QA-04	Editar nombre, eslogan, color, portada y logo	Guardado persiste en BD, recarga y otro navegador
QA-05	Publicar/ocultar A	Aparece y desaparece en Explorar, respetando RLS
QA-06	Enlace directo a perfil	Carga sin falso error; contempla sesión y no sesión
QA-07	Portada JPG/PNG/WebP, 0 bytes, >5 MB, MIME inválido	Rechaza con explicación, no deja huérfanos
QA-08	Post de texto publicado, borrador y multimedia	Visibilidad y Storage correctos; borrado verificable
QA-09	Añadir/editar/desactivar servicio	Solo empresa activa; catálogo Cliente sincronizado
QA-10	Seguir/dejar de seguir negocio	Persiste entre sesiones; feed asociado correcto
QA-11	Crear/editar/publicar sede, pin y horario	Ubicación exacta voluntaria; mapa de Cliente correcto
QA-12	Borrar sede secundaria y principal	Confirmación por nombre, permisos, estado y no cascadas ajenas
QA-13	Cliente A solicita servicio a Empresa B	Solicitud y CRM de empresa; actividad de cliente
QA-14	Empresa acepta/rechaza/completa	Estado visible en Cliente y sin acceso de terceros
QA-15	Cliente inicia chat y Empresa responde	Mensajes persisten en dos navegadores
QA-16	Mensaje con PDF/TXT/imagen y descarga	Miembros pueden; tercero recibe denegación
QA-17	No leídos, pestaña sin foco y regreso	Cuentas y roles correctos sin exceso de escrituras
QA-18	Guardar módulos en A y luego abrir B sin preferencias	Selecciones no contaminadas
QA-19	Crear proyectos, tareas, borradores y estados	Persistencia por empresa; casos límite
QA-20	Teclado, lectores, móvil real, zoom 200 %	Navegación comprensible y accesible

ID	Recorrido	Aceptación
QA-21	Concurrente: 2 pestañas modifican empresa y mensajes	Sin pérdida silenciosa ni respuestas obsoletas
QA-22	Red lenta, offline temporal, 401/403/429/500	Mensaje útil; sin afirmar guardado si falla
QA-23	Intentos de UUID ajeno en tablas/ Storage	RLS y restricciones deniegan lectura/ escritura
QA-24	Navegación Cliente: abrir/cerrar/atrás/ adelante	Historial coherente, no reapertura involuntaria

Cobertura de compatibilidad mínima

- Chrome/Edge escritorio (Chromium), Firefox escritorio, Safari macOS.
- Safari iPhone físico (incluyendo selector nativo), Chrome Android físico, tablet iPad/Android.
- 320, 360, 375, 390, 430, 768, 1024, 1440 píxeles; orientación vertical/horizontal.
- Red lenta, pérdida de red, botón Atrás, cambio de pestaña, sesión caducada, modo claro/oscuro.
- VoiceOver/TalkBack, teclado, zoom 200 %, `prefers-reduced-motion`, alt, contraste y nombres accesibles.

7. Mejoras de producto posteriores a la estabilización

Nivel 1: experiencia consistente. Mostrar claramente organización activa; evitar confusión entre empresa y sede; crear centro de gestión de tiendas; logo/portada persistentes y vista previa; URL pública externa; botones «Contactar», «Seguir» y acciones sin mezclar operativa interna.

Nivel 2: relación social y confianza. Feed de empresas seguidas, fotos/videos de servicios, publicaciones y galerías destacadas; notificaciones internas; reportar/bloquear; perfiles con descripción y contacto útiles; búsquedas relevantes sin inventar valoraciones.

Nivel 3: profesional modular. Herramientas por sector, CRM consistente, agenda y trabajos; módulos configurables por empresa, no por sesión; servicios/productos diferenciados; presupuesto real y reservas **solo cuando** exista autorización, concurrencia, calendario y normas de negocio.

Nivel 4: marketplace y escala. Descubrimiento público SEO, mapa geográfico con puntos autorizados, ranking y filtros eficientes, límites razonables de media, roles de empleados, observabilidad, pagos/ facturación regulada y protección de datos.

8. Plan de ejecución recomendado para Codex

Fase A — Alto riesgo, antes de más funcionalidades: crear staging + cuentas QA, documentar matriz de roles y RLS, reparar lectura anónima para futuros perfiles públicos, activar leaked-password protection, ejecutar E2E autenticados básicos; disponer de prueba de rollback y limpieza de datos.

Fase B — Corregir bugs de contexto y navegación: `BusinessTools` al cambiar organización, arrays/ requests obsoletos en `RealExperience`, historial de Cliente y acceso directo al perfil. Definir cómo se presenta el borrado de sede frente al de empresa. Añadir tests móviles autenticados para el selector y «Eliminar».

Fase C — Persistencia y operaciones: portadas/storage sin huérfanos, CRUD completo de catálogo, borrado seguro, publicación de sedes, mapa, chat adjuntos y estados de solicitudes en dos identidades.

Fase D — Pruebas y lanzamiento: suite E2E en CI con Firefox/WebKit/Chromium, pruebas de red y accesibilidad, manifiesto de versión del deploy, smoke post-despliegue, errores observables y procedimiento de rollback. Actualizar README/ROADMAP.

Fase E — Evolución comercial: reserva con disponibilidad real, catálogo por sector, moderación y notificaciones, pagos/facturación solo después de definir cumplimiento y coste.

Definición de «terminado» para cada incidencia

1. Bug reproducido con pasos y ambiente identificados.
2. Causa encontrada en componente/consulta/migración.
3. Arreglo probado en escenario positivo **y** negativo.
4. Test automático ejecutado que falla antes y pasa después (donde sea posible).
5. Prueba en staging con sesión real; después prueba en web desplegada.
6. Captura o registro, SHA del commit y evidencia del despliegue.
7. Sin modificar cuentas, tiendas, mensajes ni archivos de producción sin autorización.

Instrucción lista para entregar a Codex

> **Trabaja sobre `quimfuentes28code/EZ-SHOP`. Lee `AGENTS.md`, `docs/ESPECIFICACION_MAESTRA.md` y este informe. Prioriza en orden P0, P1, P2. No declares que algo funciona por una compilación o por un regex sobre código fuente. Monta pruebas E2E autenticadas con datos sintéticos y limpieza, verifica aislamiento RLS y compara staging con Cloudflare. Empieza por reproducir las incidencias de `BusinessTools` entre empresas, falta de usuario anónimo sobre perfiles publicados, navegación/history de Cliente, confusión empresa-sede y botón Eliminar en móvil. No borres ninguna empresa ni datos reales. No debilites RLS. Documenta cada hallazgo, commit, prueba y resultado; no implemente pagos, facturación ni reservas automáticas antes de cerrar el núcleo.**

9. Evidencias y enlaces

- Código principal: https://github.com/quimfuentes28code/EZ-SHOP/tree/main
- Auditoría externa multi navegador: https://github.com/quimfuentes28code/EZ-SHOP/actions/runs/40982101322
- Capturas y JSON: artefacto `deep-live-audit-20261030` en la ejecución anterior.
- Compilación principal tras PR #16: https://github.com/quimfuentes28code/EZ-SHOP/actions/runs/40979936103
- Suite local E2E completa (16 fallos/27): https://github.com/quimfuentes28code/EZ-SHOP/actions/runs/40982450589
- PR perfil y selector móvil: https://github.com/quimfuentes28code/EZ-SHOP/pull/15
- PR borrar sedes: https://github.com/quimfuentes28code/EZ-SHOP/pull/16
- Audit anterior de base de datos: https://github.com/quimfuentes28code/EZ-SHOP/blob/main/docs/AUDITORIA_WEB_2026-10-30.md
- Supabase Password Security: https://supabase.com/docs/guides/auth/password-security#password-strength-and-leaked-password-protection
- Supabase Storage público/privado: https://supabase.com/docs/guides/storage/buckets/fundamentals

- Supabase Storage: borrar archivos vía API: https://supabase.com/docs/guides/storage/management/delete-objects

Precisión final: una web que carga sin errores es un buen punto de partida, no un certificado de funcionamiento de sus transacciones. La auditoría justifica continuar el desarrollo y una fase de QA autenticada sistemática, pero no un lanzamiento abierto. Este informe es un documento de trabajo para Codex, no una certificación de seguridad, accesibilidad o cumplimiento legal.

---

158 casos de aceptación

AutonoService — Plan de pruebas de aceptación exhaustivo para Codex

Fecha: 30/10/2026 · **Fuente:** auditoría integral del repositorio, web y Supabase.

> **No confundir esta matriz con pruebas realizadas.** Son casos de aceptación reproducibles **pendientes de ejecutar con cuentas QA**. La auditoría externa 382/382 y el SQL reversible se detallan por separado en el informe principal. La suite E2E histórica obtuvo 11/27 correctos. Ningún caso de esta matriz se considera superado por el mero hecho de existir el código.

Condiciones previas y seguridad

1. Utilizar **Supabase staging** aislado y cuatro identidades sintéticas (Empresa A, Empresa B, Cliente A, Cliente B), más una con doble rol. Conservar las dos empresas existentes de producción sin alterarlas.
2. Ejecutar el mismo conjunto en **Chromium, Firefox, WebKit**; repetir los casos táctiles en Safari iPhone y Chrome Android físicos.
3. No escribir contraseñas, tokens, emails reales, chats reales o documentos de clientes en informes ni logs; datos temporales etiquetados `QA_` y limpieza automática.
4. Para cada caso registrar: **resultado PASA/FALLA/BLOQUEADO**, entorno, SHA, captura o traza, respuesta HTTP, consulta o política RLS, responsable y enlace a PR.
5. Un fallo no se corrige modificando el test para que pase sin revisar el contrato; un test de demostración no valida Supabase real.

Resumen por prioridad

Total: 158 casos; 79 P0, 77 P1 y 2 P2.

A. Identidad, sesión y permisos de entrada (15 casos)

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
A-01	P0	Registro Empresa válido	Crear identidad nueva, verificar correo, acceder y recargar	Cuenta Empresa activa sin duplicados	Pendiente QA
A-02	P0	Registro Cliente válido	Registrar una cuenta Cliente nueva y confirmar correo	Cliente gratuito con perfil propio	Pendiente QA
A-03	P0	Email sin confirmar	Intentar acceder antes de confirmar correo	Explicación clara sin acceso indebido	Pendiente QA
A-04	P0	Contraseña incorrecta	Probar clave errónea cinco veces sin capturar información sensible	Error controlado, sin filtración de existencia de cuenta	Pendiente QA
A-05	P0	Un correo con dos espacios	Activar Cliente desde cuenta Empresa	Misma identidad, roles diferenciados	Pendiente QA
A-06	P0	Otro correo en misma sesión	Salir de A y entrar como B	Sin datos de A visibles después del cambio	Pendiente QA
A-07	P0	Recarga con sesión activa	Recargar durante Perfil, Sedes, Mensajes y Mi actividad	Sesión válida y ruta esperada	Pendiente QA
A-08	P1	Caducidad y renovación	Forzar expiración JWT en staging	Renovación o retorno a login sin loops	Pendiente QA
A-09	P0	Logout completo	Cerrar sesión, volver atrás y refrescar	Datos privados no expuestos	Pendiente QA
A-10	P1	Apertura desde enlace protegido	Abrir URL Empresa desde navegador sin sesión	Login y retorno lógico tras autenticar	Pendiente QA
A-11	P1	Dos pestañas misma cuenta	Cerrar sesión en una y actuar en la otra	Estado coherente, sin acciones indebidas	Pendiente QA
A-12	P1	Restablecimiento contraseña	Solicitar reset, caducar enlace y usar nuevo	Flujo seguro de recuperación	Pendiente QA

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
A-13	P1	Validaciones alta	Nombre, longitud, email, contraseña débil, caracteres Unicode	Mensajes y límites correctos	Pendiente QA
A-14	P2	Autocompletar y llavero	Usar password manager en iPhone/Android	Campos con atributos adecuados	Pendiente QA
A-15	P0	Sin rol habilitado	Autenticar y abrir el espacio no activado	Oferta de activación y RLS aplicado	Pendiente QA

B. Empresa activa y aislamiento visual (12 casos)

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
B-01	P0	Cambio A a B en escritorio	Desde Inicio, alternar empresas dos veces	Nombre, servicios, CRM y solicitudes correctos	Pendiente QA
B-02	P0	Cambio A a B en iPhone	Con dos empresas, cambiar selector superior táctil	Cambia sin esconder o recortar controles	Pendiente QA
B-03	P0	Cambio A a B en tablet	Alternar en 768px con orientación horizontal y vertical	Selector accesible y estado coherente	Pendiente QA
B-04	P0	Cambio en sección Servicios	Mantener Servicios abierta y cambiar empresa	No aparecen servicios de A en B	Pendiente QA
B-05	P0	Cambio en sección Herramientas	Guardar módulos en A y elegir B sin fila de preferencias	B no hereda módulos de A	Pendiente QA
B-06	P0	Retorno de B a A	Cambiar de vuelta tras editar en B	Datos y preferencias de A intactos	Pendiente QA
B-07	P0	Respuesta tardía de A	Simular red lenta, cambiar A a B antes de completar carga	Respuesta vieja no sobrescribe UI de B	Pendiente QA
B-08	P1	Cambio con formulario sin guardar	Introducir cambios en A y cambiar a B	No se guarda borrador en negocio incorrecto	Pendiente QA

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
B-09	P1	Cambios de sesión simultáneos	Cambiar cuenta y empresa rápidamente	Sin filtración entre identidades	Pendiente QA
B-10	P1	Cero empresas asociadas	Abrir Empresa en usuario nuevo sin negocios	Crear empresa sin error ni selector vacío	Pendiente QA
B-11	P1	Una sola empresa asociada	Abrir Empresa con una organización	Selector innecesario no bloquea navegación	Pendiente QA
B-12	P0	Varias empresas heredadas	Cuenta anterior con dos empresas	Permite escoger ambas sin duplicarlas	Pendiente QA

C. Perfil comercial y publicación (17 casos)

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
C-01	P0	Guardar nombre y descripción	Modificar, recargar, abrir en Cliente	Valores persistentes solo de empresa editada	Pendiente QA
C-02	P0	Guardar eslogan y color	Editar, recargar y consultar como Cliente	Valores equivalentes en ambos espacios	Pendiente QA
C-03	P0	Portada JPG válida	Subir foto no sensible y recargar	Imagen persiste y se ve en Cliente	Pendiente QA
C-04	P0	Portada WebP válida	Repetir con WebP en móvil	Imagen cargada y representada correctamente	Pendiente QA
C-05	P0	Logo PNG válido	Subir logo y cambiar de empresa	Logo correspondiente a cada perfil	Pendiente QA
C-06	P0	Actualizar portada dos veces	Subir dos fotos y repetir apertura	La última se muestra sin caché obsoleta	Pendiente QA
C-07	P1	MIME/archivo falso	Renombrar TXT como JPG y subir	Rechazo sin publicación engañosa	Pendiente QA
C-08	P1	Imagen 0 bytes	Intentar cargar imagen vacía	Error comprensible, sin URL grabada	Pendiente QA
C-09	P1	Imagen superior a 5MB	Subir imagen de 6MB	Tamaño validado, no deja registro inconsistente	Pendiente QA

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
C-10	P0	Publicar empresa	Cambiar de privado a público desde Empresa	Cliente autorizado descubre negocio	Pendiente QA
C-11	P0	Ocultar empresa	Despublicar mientras Cliente tiene abierto el perfil	Deja de aparecer tras refrescar/ foco	Pendiente QA
C-12	P0	Perfil directo con UUID	Abrir URL guardada antes de cargar directorio	No error de 'no disponible' temporal	Pendiente QA
C-13	P1	Perfil compartido sin login	Abrir URL en incógnito	Comportamiento conforme al contrato público definido	Pendiente QA
C-14	P1	Botón compartir	Copiar enlace y abrir en otro navegador	URL de negocio correcto, sin parámetros ajenos	Pendiente QA
C-15	P1	Portada con error de red	Bloquear Storage con DevTools	Fondo alternativo y aviso adecuado	Pendiente QA
C-16	P1	Eslogan largo y caracteres especiales	Guardar acentos, emoji y límites	No desbordamiento ni HTML ejecutable	Pendiente QA
C-17	P1	Foto de otra empresa	Intentar guardar URL ajena en organización propia	Backend impide referencias o exposición indebida	Pendiente QA

D. Publicaciones, novedades y favoritos (13 casos)

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
D-01	P0	Publicación de texto	Crear y publicar desde Empresa	Visible en Cliente y feed de seguidores	Pendiente QA
D-02	P0	Borrador privado	Guardar texto como borrador	No visible para otros clientes	Pendiente QA
D-03	P0	Publicación con foto	Subir imagen y publicar	Foto se ve en perfil y novedades	Pendiente QA
D-04	P0	Publicación con vídeo	Subir MP4/WebM válido	Reproduce en navegadores compatibles	Pendiente QA

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
D-05	P1	Archivo multimedia inválido	SVG, HTML, MIME incorrecto y archivo grande	Validación clara y sin publicación	Pendiente QA
D-06	P0	Eliminar publicación	Borrar post con foto desde Empresa	Desaparece de Cliente y se intenta limpiar Storage	Pendiente QA
D-07	P0	Retirar post privado con media	Intentar ocultar multimedia ya público	Advierte URL pública y requiere eliminación	Pendiente QA
D-08	P1	Lista de 120+ posts	Abrir publicaciones con múltiples páginas	Paginación definida; no perder posts antiguos	Pendiente QA
D-09	P1	Feed sin favoritos	Abrir Novedades sin seguir negocios	Estado vacío y CTA apropiado	Pendiente QA
D-10	P0	Añadir favorito	Seguir empresa desde Cliente	Persiste entre dispositivos	Pendiente QA
D-11	P0	Eliminar favorito	Dejar de seguir negocio	No aparece en favoritos ni feed	Pendiente QA
D-12	P0	Favoritos cruzados	Cliente A sigue X y Cliente B sigue Y	Sin ver listas privadas del otro	Pendiente QA
D-13	P1	Empresa despublicada seguida	Ocultar empresa que estaba en favoritos	Feed y favoritos no filtran contenido privado	Pendiente QA

E. Sedes, tiendas y mapa (18 casos)

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
E-01	P0	Crear primera sede	Crear desde Empresa con nombre y ciudad	Sede guardada, sin afectar otras empresas	Pendiente QA
E-02	P0	Crear sede secundaria	Añadir nueva localización a empresa existente	Aparece solo en su empresa	Pendiente QA
E-03	P0	Editar nombre/ dirección	Cambiar sede y recargar	Campos persistentes y coherentes	Pendiente QA

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
E-04	P0	Guardar horarios	Seleccionar días, apertura y cierre	Reglas de calendario validadas	Pendiente QA
E-05	P1	Horarios inválidos	Misma apertura/ cierre, sin días marcados	Rechazo con mensaje útil	Pendiente QA
E-06	P0	Publicar ubicación	Marcar sede visible y asignar lat/lon desde mapa	Pin solo si permisos y coordenadas válidas	Pendiente QA
E-07	P0	Ocultar ubicación	Despublicar sede publicada	Pin desaparece de Cliente	Pendiente QA
E-08	P1	Probar mapa vacío	Acceder sin coordenadas publicadas	Estado vacío informativo, cero pines ficticios	Pendiente QA
E-09	P1	Mapa con múltiples sedes	Publicar varios puntos reales sintéticos en staging	Pines identificados y perfil correcto al tocarlos	Pendiente QA
E-10	P1	Mapa sin CDN	Bloquear Leaflet y teselas externas	Mensaje de recuperación, sin bloquear resto de app	Pendiente QA
E-11	P0	Eliminar sede secundaria	Tocar Eliminar, escribir nombre exacto y aceptar	Solo sede seleccionada eliminada	Pendiente QA
E-12	P0	Cancelar eliminación	Abrir confirmación y cancelar	Registro intacto	Pendiente QA
E-13	P0	Confirmación incorrecta	Escribir nombre incompleto o distinto	Botón definitivo deshabilitado	Pendiente QA
E-14	P0	Eliminar sede principal	Ejecutar en staging y revisar principal restante	Comportamiento documentado y coherente	Pendiente QA
E-15	P0	Borrado por no propietario	Usuario B intenta borrar sede de A	RLS deniega; registro persiste	Pendiente QA
E-16	P1	Sede vs empresa	Buscar eliminar RedMoonStudios desde selector	Acciones diferenciadas y sin pérdida accidental	Pendiente QA
E-17	P1	Coordenadas fuera de rango	Lat 100 o lon 200 por API de QA	CHECK SQL impide valores inválidos	Pendiente QA

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
E-18	P1	Localización móvil	Permiso de ubicación denegado	Buscar por ciudad sigue operativo	Pendiente QA

F. Servicios, solicitudes y CRM (16 casos)

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
F-01	P0	Crear servicio	Agregar título, precio y organización activa	Persistencia solo en empresa correcta	Pendiente QA
F-02	P1	Precio negativo	Intentar guardar -1€ por UI/API	Validación bloquea importe inválido	Pendiente QA
F-03	P1	Servicio inactivo	Desactivar servicio desde gestión	No aparece como contratable en Cliente	Pendiente QA
F-04	P1	Editar servicio	Modificar nombre/precio y recargar	Cambios correctos en Empresa y Cliente	Pendiente QA
F-05	P1	Eliminar servicio	Solicitar borrado de servicio con solicitudes	Manejo explícito de FK, sin pérdida de historial	Pendiente QA
F-06	P0	Solicitud válida	Cliente B solicita servicio de Empresa A	La ven ambas partes, vinculada a servicio correcto	Pendiente QA
F-07	P0	Cambio de estado	Empresa A acepta o rechaza una solicitud	Cliente B ve estado actualizado	Pendiente QA
F-08	P0	Finalización de solicitud	Empresa A marca como completada	Historial coherente en ambas áreas	Pendiente QA
F-09	P0	Solicitud entre empresas	Cliente solicita a dos empresas diferentes	Dos historiales independientes	Pendiente QA
F-10	P0	Solicitud cruzada ajena	Empresa C intenta leer solicitud de A	RLS deniega lectura	Pendiente QA
F-11	P1	Fecha deseada inválida	Fecha pasada, imposible, o vacía opcional	Reglas acordadas y mensajes claros	Pendiente QA

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
F-12	P1	Doble envío	Doble toque en solicitud con red lenta	Sin duplicados por pulsaciones accidentales	Pendiente QA
F-13	P1	CRM originado por solicitud	Enviar solicitud nueva y revisar CRM	Ficha con datos autorizados únicamente	Pendiente QA
F-14	P1	CRM cliente sin solicitud	Intentar ver perfil de Cliente ajeno	Acceso denegado	Pendiente QA
F-15	P1	Cambios de contacto	Cliente actualiza teléfono tras solicitud	Semántica snapshot/vivo definida	Pendiente QA
F-16	P1	Lista de solicitudes vacía	Cuenta nueva sin movimientos	Estado vacío comprensible	Pendiente QA

G. Conversaciones, archivos y avisos (20 casos)

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
G-01	P0	Iniciar conversación	Cliente B contacta Empresa A por perfil	Se crea exactamente un hilo Cliente/ Empresa	Pendiente QA
G-02	P0	Mensaje texto Cliente→Empresa	Enviar mensaje, esperar polling	Aparece correctamente en bandeja Empresa	Pendiente QA
G-03	P0	Respuesta Empresa→Cliente	Responder desde empresa activa	Cliente recibe texto tras refresco	Pendiente QA
G-04	P0	Mensaje al cambiar de empresa	Abrir hilo de A, cambiar a B	No permite enviar contenido desde negocio erróneo	Pendiente QA
G-05	P0	Dos roles misma identidad	Usar Empresa y Cliente con un usuario con ambos roles	Las bandejas no mezclan identidades operativas	Pendiente QA
G-06	P0	Adjuntar JPG	Enviar fichero permitido con cuenta de prueba	Archivo accesible solo participantes	Pendiente QA
G-07	P0	Adjuntar PDF	Enviar PDF sintético y descargar como destinatario	Nombre/ contenido conservados	Pendiente QA
G-08	P0	Adjuntar TXT	Enviar TXT, descargar en otro navegador	Contenido coincide con original	Pendiente QA

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
G-09	P0	Adjuntar prohibido	Intentar SVG, HTML, EXE y ZIP en chat real	Rechazo claro para formatos no admitidos	Pendiente QA
G-10	P0	Adjunto de 11MB	Enviar mayor de 10 MB	Error sin almacenamiento residual	Pendiente QA
G-11	P0	Descarga ajena de adjunto	Cuenta C pide URL firmada de hilo A-B	Storage deniega	Pendiente QA
G-12	P0	Link firmado caducado	Abrir enlace privado después de expirar	No acceso y renovación autorizada	Pendiente QA
G-13	P0	Contador no leídos	Cliente envía, Empresa no abre conversación	Contador incrementa y se limpia al leer	Pendiente QA
G-14	P1	Polling con pestaña inactiva	Dejar 10 min sin interacción	No sobrecarga de API ni bucle de renders	Pendiente QA
G-15	P1	Mensaje simultáneo	Dos pestañas envían al mismo hilo	Orden razonable y sin duplicación	Pendiente QA
G-16	P1	Fallo al subir fichero	Simular desconexión durante upload	No mensaje falsamente enviado	Pendiente QA
G-17	P1	Riesgo orphan upload	Upload completo y fallo en insert de mensaje	Limpieza de objeto o tarea de reparación	Pendiente QA
G-18	P1	Aviso de spam y bloqueo	Intentar enviar repetidamente en staging	Rate limiting y mecanismo de reporte antes de público	Pendiente QA
G-19	P1	Enter en chat demo	Enviar con Enter y Shift+Enter	Comportamiento documentado, sin perder mensaje	Pendiente QA
G-20	P1	Regreso de demo Empresa a Cliente	Intercambiar perspectiva tras guardar mensaje demo	Hilo demo consistente, sin confundirse con chat real	Pendiente QA

H. Herramientas, planificación y módulos (13 casos)

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
H-01	P0	Guardar módulos en A	Seleccionar 3 y recargar	Configuración persistente en A	Pendiente QA

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
H-02	P0	B sin módulos previos	Cambiar a B sin fila guardada	Lista limpia, no hereda de A	Pendiente QA
H-03	P0	Cambios con red lenta	Cambiar antes de recibir módulos previos	Respuesta tardía ignorada	Pendiente QA
H-04	P1	Guardar vacío	Desmarcar todas las opciones y guardar	Estado vacío representado explícitamente	Pendiente QA
H-05	P1	Crear proyecto interno	Nuevo proyecto y recarga	Persistencia por empresa	Pendiente QA
H-06	P1	Cambiar estado de proyecto	Pendiente → en curso → terminado	Estado correcto al refrescar	Pendiente QA
H-07	P1	Crear cita interna	Añadir fecha y guardar	No se presenta como reserva pública	Pendiente QA
H-08	P1	Crear presupuesto borrador	Título, importe y fecha	No implica factura ni cobro	Pendiente QA
H-09	P1	Crear orden de trabajo	Registrar descripción	Visible solo en empresa activa	Pendiente QA
H-10	P1	Crear encargo interno	Agregar y actualizar	Sin confundir con pedido público	Pendiente QA
H-11	P1	Importe inválido	NaN, negativo, sobre máximo y decimales	Validaciones en cliente y servidor	Pendiente QA
H-12	P1	Cambio de negocio con workboard	Crear proyecto en A, abrir B	B no lista el proyecto de A	Pendiente QA
H-13	P2	Herramientas en desarrollo	Abrir catálogo completo	No aparentan ser operativas funciones sin backend	Pendiente QA

I. Seguridad, consentimiento y operaciones de datos (18 casos)

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
I-01	P0	RLS de 14 tablas	Consultar cada tabla como dueño, ajeno y anónimo	Aislamiento con respuestas verificables	Pendiente QA

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
I-02	P0	Anónimo con organizaciones publicadas	Consultar directorio anónimo	Solo negocios públicos y sin error de permiso	Pendiente QA
I-03	P0	Anónimo con publicaciones	Consultar posts públicos sin cuenta	Sin revelar borradores ni error de política	Pendiente QA
I-04	P0	Archivo público vs privado	Intentar acceder sin sesión a media y adjuntos	Solo media autorizada pública	Pendiente QA
I-05	P0	Cambiar UUID manualmente	Manipular rutas y parámetros de empresa ajena	Ningún dato privado devuelto	Pendiente QA
I-06	P0	Payload JSON forjado	Enviar IDs ajenos en insert/update API	RLS y FK impiden modificaciones	Pendiente QA
I-07	P0	Roles en mismo correo	Alternar identidad y `actor_role` en mensajes	Solo acciones permitidas por rol	Pendiente QA
I-08	P0	Contraseñas filtradas	Habilitar protección y probar cadena comprometida en staging	Rechazo claro y auditado	Pendiente QA
I-09	P1	Storage limpieza	Eliminar publicación con media de test	Borrar vía API y verificar no huérfanos	Pendiente QA
I-10	P1	Público despublicado ya descargado	Retirar publicación multimedia	Documentar imposibilidad de revocar copias previas	Pendiente QA
I-11	P1	Inyección XSS	Publicar texto HTML o nombres con etiquetas	Renderizado como texto seguro	Pendiente QA
I-12	P1	Datos especialmente sensibles	Intentar adjuntar documento con datos simulados	Mensajes y políticas explícitas, moderación	Pendiente QA
I-13	P1	Ratelimit de login/chat	Simular ráfaga controlada con test aislado	429 y recuperación adecuada	Pendiente QA
I-14	P1	Conflicto de escritura	Dos pestañas editan mismo perfil	No pierde datos silenciosamente	Pendiente QA
I-15	P1	Exportación/ borrado de identidad	Solicitar copia y supresión de usuario	Proceso y política definidos antes de apertura	Pendiente QA

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
I-16	P1	Copia de seguridad	Restaurar backup en staging	Datos íntegros y recuperación documentada	Pendiente QA
I-17	P1	Observabilidad	Simular 401, 403, 400, 429 y 500	Logs con trazabilidad sin PII expuesta	Pendiente QA
I-18	P1	Auditoría de dependencias	Revisar Next, React, Supabase y Leaflet	Sin vulnerabilidades conocidas relevantes	Pendiente QA

J. Compatibilidad, accesibilidad y despliegue (16 casos)

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
J-01	P1	Safari iPhone físico	Navegar, seleccionar empresa, subir portada y borrar sede QA	Todos los controles operativos	Pendiente QA
J-02	P1	Firefox desktop	Navegar formularios de demo y cuenta de prueba	Sin errores de renderizado	Pendiente QA
J-03	P1	Chrome Android físico	Abrir mensajes, formularios y mapa	Teclado y touch no bloquean funciones	Pendiente QA
J-04	P1	Safari iPad real	Cambiar orientación con panel abierto	Sin menús inaccesibles	Pendiente QA
J-05	P1	Pantalla de 320px	Explorar, mensajes y perfil con zoom	Sin desbordamientos críticos	Pendiente QA
J-06	P1	Zoom 200%	Navegar con zoom sin teclado de ratón	Texto refluye y botones accesibles	Pendiente QA
J-07	P1	VoiceOver/ TalkBack	Recorrer controles en móvil real	Nombres, estados y orden lógico	Pendiente QA
J-08	P1	Navegación solo teclado	Tab, Shift+Tab, Enter, Escape	Foco visible y formularios utilizables	Pendiente QA
J-09	P1	Contraste y temas	Comparar claro/ oscuro e inversión de colores	Contraste legible y persistencia	Pendiente QA

ID	Prioridad	Escenario	Procedimiento	Aceptación	Estado
J-10	P1	Movimiento reducido	Activar prefers-reduced-motion	Animaciones respetan preferencia	Pendiente QA
J-11	P1	Conexión lenta/ offline	Emular 3G y desconexión	Errores informativos y reintentos	Pendiente QA
J-12	P0	Verificar SHA desplegado	Comparar Cloudflare con commit de main	Versión/fecha trazable, no solo strings JS	Pendiente QA
J-13	P0	Smoke posdespliegue	Publicar nueva versión y recorrer ruta pública + login QA	Sin regresiones evidentes	Pendiente QA
J-14	P0	E2E actualizados	Ejecutar suite completa contra UI vigente	0 fallos; documentar tests migrados y nuevos	Pendiente QA
J-15	P1	Paridad web vs demo	Alternar demo/ real sin cruzar almacenamiento	Datos demo ficticios y real nunca mezclados	Pendiente QA
J-16	P1	Rollback verificable	Desplegar a staging, revertir y repetir smoke	Proceso predecible y documentación completa	Pendiente QA

Puerta de salida para apertura pública

No declarar apta para producción hasta que los P0 activos estén superados en QA con sesiones reales, aislamiento probado y medidas de seguridad habilitadas. Los casos P1 relacionados con accesibilidad, prevención de abuso, gestión de datos y restauración deben cerrarse o estar justificados expresamente antes de captar clientes reales.

Evidencias de referencia: Auditoría externa 382/382, Suite E2E 11/27, PR #17 auditoría, PR #18 contexto empresarial.

Instrucciones para Codex

Instrucciones para Codex — Continuación de AutonoService tras la auditoría integral

Trabaja sobre el repositorio `quimfuentes28code/EZ-SHOP` y la especificación de producto vigente. **Lee primero** `AGENTS.md`, `docs/ESPECIFICACION_MAESTRA.md`, el historial de migraciones y los adjuntos `AUTONOSERVICE_AUDITORIA_INTEGRAL_2026-10-30.md` y `AUTONOSERVICE_PLAN_PRUEBAS_EXHAUSTIVO_2026-10-30.md`.

Contexto y evidencias

- `main` analizado en `773c6d7c653c98ae548e4e4087c3bf29d492d5db`.
- PR de auditoría con scripts reproducibles: https://github.com/quimfuentes28code/EZ-SHOP/pull/17 (borrador, no fusionado).
- Smoke de producción multibrowser: **382 checks, 0 fallos** (Chromium desktop/móvil/tablet, Firefox desktop y WebKit móvil emulado): https://github.com/quimfuentes28code/EZ-SHOP/actions/runs/40982101322.
- Suite Playwright local completa: **27 tests, 11 pasan y 16 fallan**, principalmente por referencias obsoletas a las demos; diagnóstico y trazas: https://github.com/quimfuentes28code/EZ-SHOP/actions/runs/40982450589.
- Supabase tiene 14 tablas de negocio con RLS. El propietario pudo borrar una sede temporal con SQL reversible; un usuario distinto no. No se borraron registros reales.
- RedMoonCorp y RedMoonStudios están publicados; solo RedMoonCorp tiene portada/logo guardados. Las 2 sedes siguen privadas: 0 ubicaciones disponibles para el mapa público.
- Supabase Security Advisor advierte que la protección de contraseñas filtradas está deshabilitada.

Prioridades obligatorias (no añadir módulos nuevos primero)

1. **Reconstruir las pruebas E2E alrededor del producto vigente.** Separar los tests de demo local de los tests reales autenticados. Crear una base de datos staging y fixtures sintéticos, con dos propietarios, dos clientes y una identidad con ambos roles. Credenciales únicamente en secretos del CI. Limpiar los datos de prueba. Mantener pruebas negativas de acceso y permalinks.
2. **Reproducir y solucionar el error de consulta anónima**: `SET LOCAL ROLE anon; SELECT count(*) FROM public.organizations` falla con `42501 permission denied for table account_types` por RLS. Igual en publicaciones, servicios y sedes. Ajustar permisos sin desactivar RLS ni exponer datos privados.
3. **Revisar y validar PR #18 antes de duplicar trabajo**: https://github.com/quimfuentes28code/EZ-SHOP/pull/18 corrige el estado residual de módulos y limpia servicios/contactos al seleccionar empresa. La primera ejecución de test falló (https://github.com/quimfuentes28code/EZ-SHOP/actions/runs/40984514001) por un contrato obsoleto; se corrigió y la siguiente pasó TypeScript, unitarias y compilación (https://github.com/quimfuentes28code/EZ-SHOP/actions/runs/40984591264). **Sigue sin estar fusionado ni validado con dos sesiones y red lenta**. Revisar y probar, no asumir que ya está en producción; preservar segregación de conversaciones.
4. **Verificar en una sesión móvil real el botón “Eliminar tienda”** de Empresa → Tiendas y sedes. La web publicada incluye su código, pero no hay prueba autenticada. Distinguir borrar sede de borrar

empresa completa; no añadir borrado directo de organizaciones debido a FKs `ON DELETE CASCADE`. Mantener confirmación por nombre y política RLS de propietario.

5. **Arreglar historial y enlaces públicos**: `CustomerSocial.selectTab()` llama a `closeBusinessProfile()` que crea entradas de historial aunque no haya perfil abierto. Evitar back/forward errático. Los enlaces compartidos `/cliente?negocio=UUID` requieren autenticación; diseñar ruta pública sin sesión separada de acciones privadas.
6. **Resolver integridad de medios**: limpiar archivos Storage si falla UPDATE/INSERT posterior, gestionar portadas reemplazadas y no presentar medios de bucket público como secretos cuando el negocio es privado.
7. **Probar flujo completo** Empresa (crear/editar/perfil/publicar/sede/servicio) → Cliente (buscar/seguir/solicitar/chat/archivo privado) → Empresa (responder/actualizar estado) → Cliente (ver resultado), incluyendo dos navegadores, visibilidad, estados, logout y sesión caducada.
8. **Actualizar CI y documentación**: `main` compila, pero no ejecuta `npm run test:e2e`. Añadir pruebas E2E reales en CI de staging; separar escenarios demo. Añadir versión/SHA visible del despliegue, smoke posdespliegue y documentación de rollback. README y ROADMAP contienen estados antiguos.

Matriz de aceptación reproducible

El archivo `AUTONOSERVICE_PLAN_PRUEBAS_EXHAUSTIVO_2026-10-30.md` especifica **158 casos**, divididos en **79 P0, 77 P1 y 2 P2**. Marcar por caso `PASA / FALLA / BLOQUEADO / NO EJECUTADO` con evidencia (captura o traza), entorno, usuario/rol sintético, SHA y URL de ejecución. No interpretar la lista como 158 tests ya ejecutados. Dar prioridad a la ruta completa Cliente–Empresa, permisos cruzados, cambio entre RedMoonCorp/RedMoonStudios en staging, borrado de sede, medio privado, historial, anti-abuso y navegadores móviles físicos.

Criterios de entrega

Para cada defecto: pasos reproducibles, causa, cambio pequeño y seguro, caso negativo, test automático, resultado con SHA/CI, validación en staging y evidencia en el navegador publicado. Ordenar y cerrar incidencias P0, P1 y P2. Usar migraciones trazables para cambios SQL. No crear cuentas de usuarios reales ni modificar datos de producción sin autorización. No abrir funciones de reservas, pagos, facturación o IA que todavía no estén respaldadas por permisos, dominio y pruebas.

Entregables de Codex: PRs separados por riesgo, matriz «probado / no probado / fallido», capturas o trazas de móvil, informe de seguridad RLS/Storage, lista de pendientes priorizada y verificación final de Cloudflare. No declarar «100 % funciona» hasta probar flujos reales.